

Universidad Nacional Autonoma de Mexico



Facultad de Ingenieria

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Semestre: 2027-1

Practica 6

Discovery

Fecha de Entrega:

31 de Octubre del 2026

Indice

1 Desarrollo **1**

1.1 Identificacion de la direccion IP y revision de conectividad 1

1.2 Conexion por SSH y cambio al usuario root 2

1.3 Informacion del sistema 3

1.4 Revision de los procesos en ejecucion 4

1.5 Revision de la configuracion de red 6

1.5.1 Tabla de rutas 6

1.5.2 Archivo hosts 6

1.5.3 Interfaces del servidor 6

1.6 Busqueda de archivos y directorios 8

1.6.1 Busqueda por extensiones y nombres de archivo 8

1.6.2 Busqueda de respaldos comprimidos 11

1.6.3 Busqueda de nombres relacionados con contraseñas 11

1.6.4 Revision de los respaldos y del archivo passwords.txt 13

1.6.5 Busqueda de cadenas dentro de los archivos 14

1.7 Construccion y transferencia del escaner de red 14

1.8 Equipos encontrados y revision de los servicios 16

2 Actividades **18**

2.1 Actividad 1: Version del kernel 18

2.2 Actividad 2: Valor de PRETTY_NAME 18

2.3 Actividad 3: Comando del servicio SSH 19

2.4 Actividad 4: Comando del servicio Apache 19

2.5 Actividad 5: Interfaces de red configuradas 19

2.6 Actividad 6: Direccion de la interfaz eth1 20

2.7 Actividad 7: Ruta del archivo con contraseñas en claro 20

2.8 Actividad 8: Otro equipo en la red interna 21

2.9 Actividad 9: Puertos a la escucha del otro equipo 22

2.10 Actividad 10: Puerto para establecer una sesion remota 22

Referencias **23**

1. Desarrollo

1.1. Identificacion de la direccion IP y revision de conectividad

Ahora bien, primero revisamos la direccion IP de nuestra maquina EvilBox, esto por que necesitamos identificar el segmento de red en el que se encuentra webserver.

```
ip a
```

Donde en este caso, la interfaz `ens33` tiene la direccion `192.168.177.128/24`, por lo que la red que vamos a revisar es `192.168.177.0/24`. Despues de esto, ponemos el siguiente comando:

```
sudo nmap 192.168.177.0/24
```

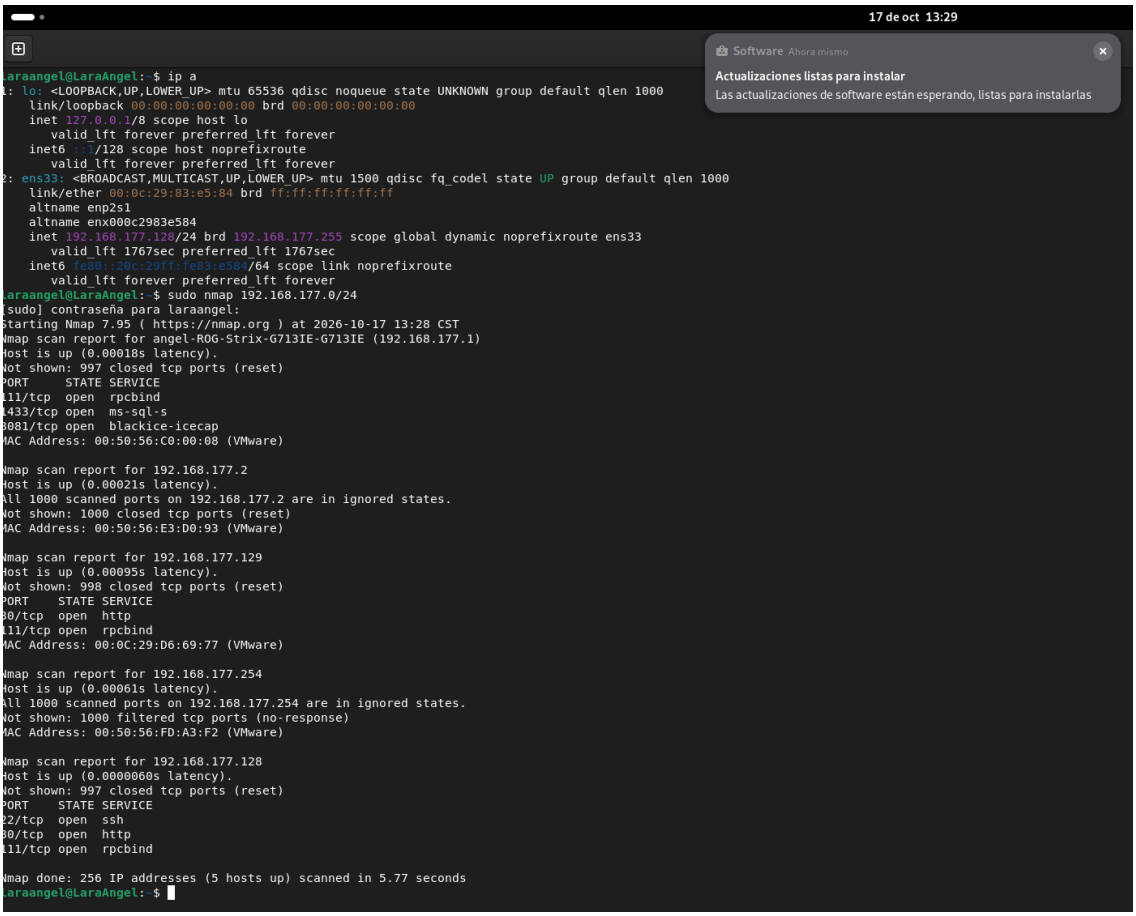


Figura 1: Revision de la direccion IP y escaneo del segmento de red.

Lo que hace nmap es revisar los equipos del segmento y los puertos TCP mas comunes. Donde `sudo` permite ejecutarlo con permisos de administracion y `/24` indica que se esta trabajando con la mascara `255.255.255.0`. En este caso se hizo el escaneo normal, por lo que ademas de encontrar equipos activos tambien se obtuvo informacion de sus puertos.

La salida nos arroja cinco equipos activos. Donde el servidor al que nos vamos a conectar es `192.168.177.129`, siendo esta la misma direccion de webserver que se utilizo en las practicas anteriores. El equipo codeserver se va a buscar despues desde la otra red a la que tiene acceso webserver.

1.2. Conexion por SSH y cambio al usuario root

Para poder conectarnos a webserver, utilizamos el usuario y la contraseña que se obtuvieron en la practica 3. Recordando que el usuario es webadmin, la contraseña es toronto y el puerto SSH es el 13337, el comando completo es el siguiente:

```
ssh webadmin@192.168.177.129 -p 13337
```

Donde `ssh` permite abrir la sesion remota y la bandera `-p` indica el puerto por el que se realiza la conexion. Despues en la consola se pone la contraseña, siendo `toronto`. En el primer intento se rechazo la contraseña y al ingresarla de nuevo se logro establecer la conexion.

```
laraangel@LaraAngel:~$ ssh webadmin@192.168.177.129 -p 13337
webadmin@192.168.177.129's password:
Permission denied, please try again.
webadmin@192.168.177.129's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Sat Oct 10 19:38:02 2026 from 192.168.177.128
webadmin@webserver:~$
```

Figura 2: Conexion por SSH al servidor con el usuario webadmin.

Ahora bien, para continuar es necesario cambiar al usuario root. Para esto ya tenemos la contraseña que se obtuvo con John en la practica 5, siendo `Maverick`, con la M mayuscula. El comando que utilizamos es el siguiente:

```
su root
```

Despues de escribir la contraseña, comprobamos el usuario con el comando whoami:

```
whoami
```

```
root
```

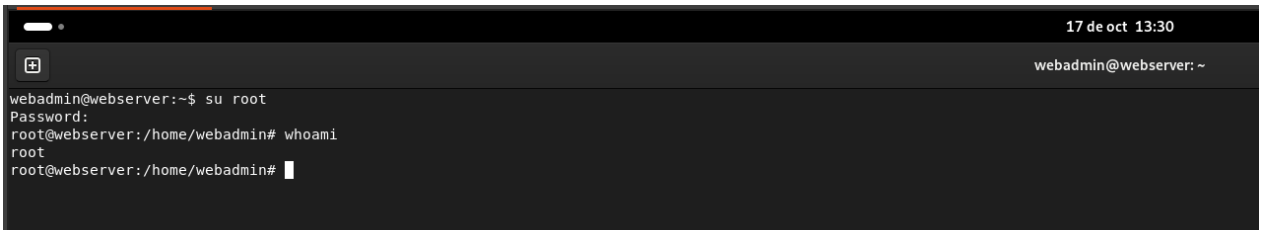


Figura 3: Cambio al usuario root y comprobacion con whoami.

Donde en este caso, whoami nos arroja root, por lo que ya tenemos los permisos necesarios para revisar la informacion del equipo.

1.3. Informacion del sistema

Para poder identificar las caracteristicas de webserver, primero revisamos la version de compilacion del kernel. Para esto, utilizamos el comando siguiente:

```
uname -v
```

```
#1 SMP Debian 3.16.56-1+deb8u1 (2018-05-08)
```

Lo que hace `uname` es mostrar informacion del sistema, donde la bandera `-v` nos da la version de compilacion del kernel. En este caso nos devuelve una compilacion de Debian identificada como `3.16.56-1+deb8u1`.

Despues de esto, revisamos los archivos que contienen la informacion de la distribucion. El comando es el siguiente:

```
cat /etc/*release | uniq
```

Donde `cat` muestra el contenido de los archivos de `/etc` que terminan en release, el simbolo `*` permite completar esa parte del nombre y la tuberia `|` pasa la salida a `uniq`, el cual quita las lineas repetidas que se encuentran una junto a otra.

```
PRETTY_NAME="Debian GNU/Linux 8 (jessie)"
NAME="Debian GNU/Linux"
VERSION_ID="8"
VERSION="8 (jessie)"
ID=debian
```

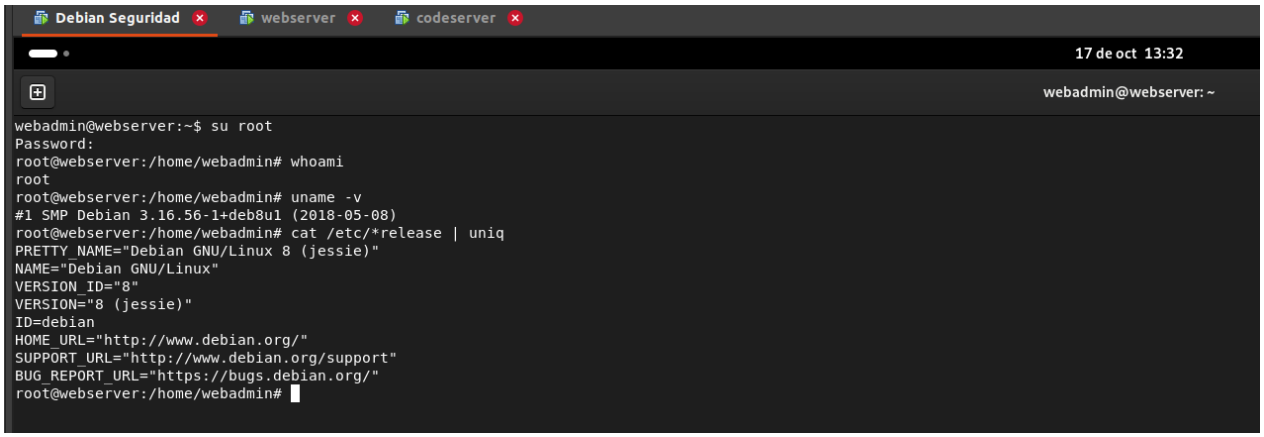


Figura 4: Version de compilacion del kernel e informacion de Debian.

Con esto podemos ver que el equipo utiliza Debian GNU/Linux 8, con el nombre jessie. Donde `PRETTY_NAME` es el nombre completo de la distribucion, mientras que `VERSION_ID` indica el numero de version.

1.4. Revision de los procesos en ejecucion

Ahora bien, para conocer los programas que se estan ejecutando en webserver.

```
ps aux awf
```

Lo que hace ps es mostrar los procesos activos en ese momento. Las opciones `a` y `x` permiten incluir procesos de otros usuarios y procesos que no tienen una terminal asociada; `u` agrega informacion del usuario y los recursos, `w` amplia la salida y `f` muestra la relacion entre los procesos en forma de arbol.

```
root@webserver:/home/webadmin# ps aux awf
USER        PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root          2  0.0  0.0      0     0 ?        S    14:27   0:00 [kthreadd]
root          3  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [ksoftirqd/0]
root          5  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [kworker/0:0H]
root          7  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [rcu_sched]
root          8  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [rcu_bh]
root          9  0.2  0.0      0     0 ?        S    14:27   0:00  \_ [migration/0]
root         10  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [watchdog/0]
root         11  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [watchdog/1]
root         12  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [migration/1]
root         13  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [ksoftirqd/1]
root         15  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [kworker/1:0H]
root         16  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [watchdog/2]
root         17  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [migration/2]
root         18  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [ksoftirqd/2]
root         20  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [kworker/2:0H]
root         21  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [khelper]
root         22  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [kdevtmpfs]
root         23  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [netns]
root         24  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [khungtaskd]
root         25  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [writeback]
root         26  0.0  0.0      0     0 ?        SN   14:27   0:00  \_ [ksmd]
root         27  0.0  0.0      0     0 ?        SN   14:27   0:00  \_ [khugepaged]
root         28  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [crypto]
root         29  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [kintegrityd]
root         30  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [bioset]
root         31  0.0  0.0      0     0 ?        S<   14:27   0:00  \_ [kblockd]
root         32  0.0  0.0      0     0 ?        S    14:27   0:00  \_ [kworker/1:1]
root         33  0.1  0.0      0     0 ?        S    14:27   0:00  \_ [kworker/2:1]
```

Figura 5: Listado de procesos y columnas de informacion del sistema.

Donde en este caso, los dos servicios que nos interesan son SSH y Apache. Para SSH se identifica el comando `/usr/sbin/sshd -D`, mientras que para Apache se encuentra `/usr/sbin/apache2 -k start`.

```
root       474  0.0  0.0   3768  2764 ?        Ss   14:28   0:00 /lib/systemd/systemd-logind
root       479  0.0  0.0   2200  1696 ?        Ss   14:28   0:00 /usr/sbin/acpid
root       482  0.0  0.1  11900  6108 ?        Ss   14:28   0:00 /usr/sbin/cupsd -f
root       483  0.0  0.1  10028  4632 ?        Ss   14:28   0:00 /usr/sbin/cups-browsed
root       486  0.0  0.1   8112  4848 ?        Ss   14:28   0:00 /usr/sbin/sshd -D
root      1123  0.0  0.1  11620  6044 ?        Ss   14:29   0:00  \_ sshd: webadmin [priv]
webadmin  1128  0.0  0.1  11620  4004 ?        S    14:29   0:00      \_ sshd: webadmin@pts/0
webadmin  1129  0.0  0.1   6672  4740 pts/0    Ss   14:29   0:00          \_ -bash
root      1139  0.0  0.0   5820  3340 pts/0    S    14:30   0:00              \_ su root
root      1140  0.0  0.0   5448  3532 pts/0    S    14:30   0:00                  \_ bash
root      1145  0.0  0.0   4932  2532 pts/0    R+   14:32   0:00                      \_ ps aux awf
root       489  0.0  0.1  37296  6916 ?        Ssl  14:28   0:00 /usr/lib/policykit-1/polkitd --no-debug
root       491  0.0  0.0   4180  1848 tty1     Ss+  14:28   0:00 /sbin/agetty --noclear tty1 linux
root       509  0.0  0.0   2180    68 ?        Ss   14:28   0:00 /usr/sbin/minissdpd -i 0.0.0.0
root       511  0.0  0.1  48800  7164 ?        Ssl  14:28   0:00 /usr/sbin/gdm3
root       527  0.1  0.5 101612 21564 tty7     Ss+  14:28   0:00  \_ /usr/bin/Xorg :0 -novtswitch -background none -noreset -verbose 3 -auth /var/run/gdm3/
root       802  0.0  0.1  29580  6636 ?        Sl   14:28   0:00  \_ gdm-session-worker [pam/gdm-launch-environment]
Debian-+   881  0.0  0.2  72068  9656 ?        Ssl  14:28   0:00  |   \_ /usr/bin/gnome-session --autostart /usr/share/gdm/greeter/autostart
Debian-+   904  0.0  0.6 177016 24020 ?       Sl   14:28   0:00  |       \_ /usr/lib/gnome-settings-daemon/gnome-settings-daemon
Debian-+   946  0.4  2.0 366808 77880 ?       Sl   14:28   0:01  |       \_ gnome-shell --mode=gdm
root      1117  0.0  0.1  29616  6376 ?        Sl   14:28   0:00  \_ gdm-session-worker [pam/gdm-password]
Debian-+   793  0.0  0.0   9928  3024 ?        Ss   14:28   0:00 /usr/sbin/exim4 -bd -q30m
root       808  0.0  0.1   6468  4368 ?        Ss   14:28   0:00 /usr/sbin/apache2 -k start
www-data   810  0.0  0.0   6268  3828 ?        S    14:28   0:00  \_ /usr/sbin/apache2 -k start
www-data   814  0.0  0.1 229100  4264 ?        Sl   14:28   0:00  \_ /usr/sbin/apache2 -k start
www-data   815  0.0  0.1 229100  4264 ?        Sl   14:28   0:00  \_ /usr/sbin/apache2 -k start
Debian-+   878  0.0  0.0   4856  3584 ?        Ss   14:28   0:00 /lib/systemd/systemd --user
```

Figura 6: Procesos de los servicios SSH y Apache en webserver.

El proceso principal de SSH tiene el PID 486 y se ejecuta como root. Para Apache, el proceso principal tiene el PID 808 y sus procesos hijos se ejecutan como www-data. Ademas de que, por medio del arbol tambien se puede relacionar la conexion SSH con la terminal que se esta utilizando.

1.5. Revision de la configuracion de red

1.5.1. Tabla de rutas

Para poder identificar a que redes tiene acceso el servidor, primero revisamos la tabla de rutas con el siguiente comando:

```
route -n
```

Donde `route` muestra las rutas del equipo y `-n` mantiene las direcciones en forma numerica, sin intentar resolver nombres. El resultado es el siguiente:

```
Destination     Gateway      Genmask          Flags   Iface
0.0.0.0         10.0.0.1     0.0.0.0          UG      eth1
10.0.0.0        0.0.0.0     255.255.255.0    U       eth1
192.168.177.0   0.0.0.0     255.255.255.0    U       eth0
```

Con esto podemos ver que eth0 esta conectada a la red `192.168.177.0/24`, mientras que eth1 esta conectada a `10.0.0.0/24`. Ademas de que, la ruta por defecto utiliza la puerta de enlace `10.0.0.1`. La bandera U indica que la ruta esta activa y G que utiliza una puerta de enlace.

1.5.2. Archivo hosts

Despues de esto, revisamos las asociaciones locales entre direcciones y nombres, esto por medio del siguiente comando:

```
cat /etc/hosts
```

El archivo contiene las entradas `127.0.0.1 localhost` y `127.0.1.1 webserver`, ademas de las entradas de IPv6. Esto permite identificar el nombre local del servidor, pero no es un listado de todos los equipos que estan conectados a la red.

1.5.3. Interfaces del servidor

Para revisar las direcciones asignadas a cada interfaz, utilizamos el siguiente comando:

```
ifconfig -a
```

Donde la bandera `-a` permite mostrar todas las interfaces, incluyendo las que no estan activas. En este caso se encuentran tres interfaces, siendo eth0, eth1 y lo.

```
root@webserver:/home/webadmin# route -n
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
0.0.0.0         10.0.0.1        0.0.0.0         UG    1024   0        0 eth1
10.0.0.0        0.0.0.0         255.255.255.0   U     0      0        0 eth1
192.168.177.0   0.0.0.0         255.255.255.0   U     0      0        0 eth0
root@webserver:/home/webadmin# cat /etc/hosts
127.0.0.1       localhost
127.0.1.1       webserver

# The following lines are desirable for IPv6 capable hosts
::1     localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
root@webserver:/home/webadmin# ifconfig -a
eth0      Link encap:Ethernet  HWaddr 00:0c:29:d6:69:6d
          inet addr:192.168.177.129  Bcast:192.168.177.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fed6:696d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1896 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1210 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:155288 (151.6 KiB)  TX bytes:105018 (102.5 KiB)
          Interrupt:19 Base address:0x2000

eth1      Link encap:Ethernet  HWaddr 00:0c:29:d6:69:77
          inet addr:10.0.0.78  Bcast:10.0.0.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fed6:6977/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:682 errors:0 dropped:0 overruns:0 frame:0
          TX packets:89 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:79058 (77.2 KiB)  TX bytes:12726 (12.4 KiB)
          Interrupt:18 Base address:0x2080

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:32 errors:0 dropped:0 overruns:0 frame:0
          TX packets:32 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:3488 (3.4 KiB)  TX bytes:3488 (3.4 KiB)

root@webserver:/home/webadmin#
```

Figura 7: Tabla de rutas, archivo hosts e interfaces de red de webserver.

Interfaz	**Direccion IPv4**	**Mascara**
eth0	192.168.177.129	255.255.255.0
eth1	10.0.0.78	255.255.255.0
lo	127.0.0.1	255.0.0.0

Donde eth0 es la interfaz por la que nos conectamos desde EvilBox y eth1 es la que nos permite revisar la red interna `10.0.0.0/24`.

1.6. Busqueda de archivos y directorios

1.6.1. Busqueda por extensiones y nombres de archivo

Ahora bien, para encontrar archivos que puedan tener informacion importante, utilizamos find. Lo que hace este comando es recorrer los directorios a partir de la ruta que se indique y buscar los nombres que coincidan con una condicion. Primero ponemos lo siguiente:

```
find /home/webadmin -name "*.pdf"
```

Donde `/home/webadmin` es el directorio desde el que se busca y `-name` compara el nombre del archivo. En este caso no se encontro ningun PDF con ese patron dentro de ese directorio.

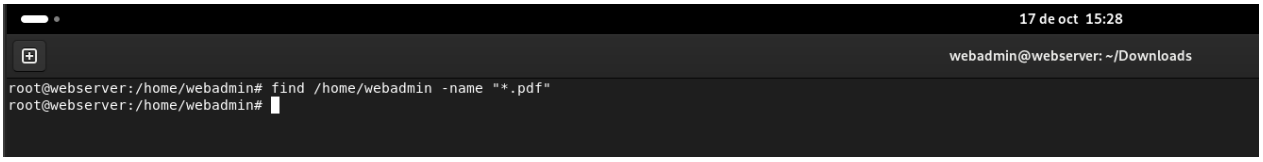


Figura 8: Busqueda de archivos PDF dentro del directorio de webadmin.

Despues de esto ampliamos la busqueda a los archivos de Python, utilizando el comando siguiente:

```
find / -name "*.py" 2>/dev/null
```

Para esto, `/` indica que la busqueda empieza desde la raiz del sistema y `*.py` permite encontrar nombres que terminen con esa extension. Las comillas evitan que la terminal complete el patron antes de pasarlo a find. Por otro lado, `2>/dev/null` descarta los mensajes de error, conservando los resultados de la busqueda.

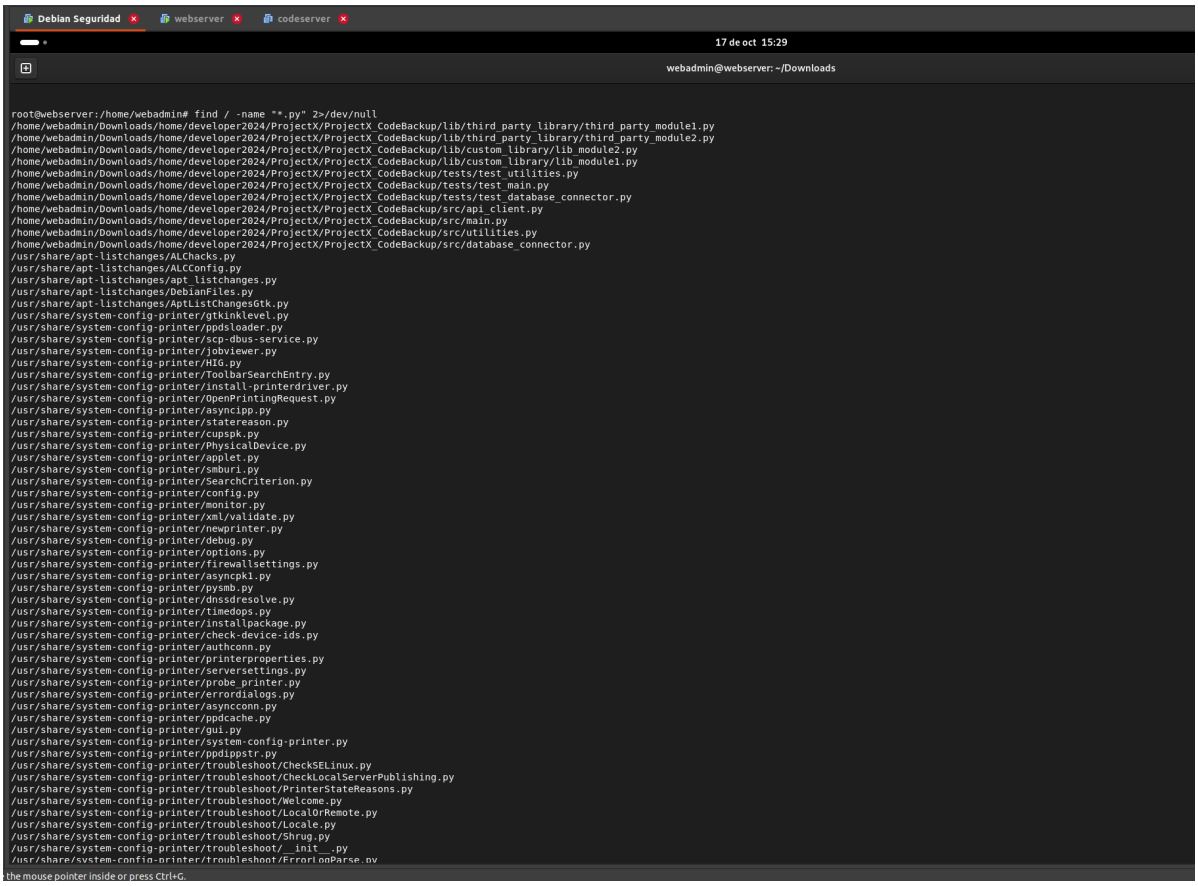


Figura 9: Busqueda de archivos de Python en el sistema.

La busqueda devuelve archivos del sistema y varios archivos de un proyecto llamado ProjectX. Donde en este caso, dentro de Downloads se encuentra el directorio `ProjectX_CodeBackup`, con archivos como main.py, api_client.py y database_connector.py, por lo que esta ruta nos sirve para continuar revisando el respaldo del proyecto.

De igual forma, se buscaron documentos de Word y nombres de archivo relacionados con contraseñas o respaldos. Los comandos son los siguientes:

```
find / -name "*.docx" 2>/dev/null
find /root -name "contraseñas.txt" 2>/dev/null
find / -name "passwords.xlsx" 2>/dev/null
find / -name "respaldo.zip" 2>/dev/null
```

Donde en este caso, estas cuatro busquedas no devolvieron coincidencias. Para buscar dentro del directorio del usuario root se utilizo `/root`, que es la ruta que tiene este usuario en el servidor.

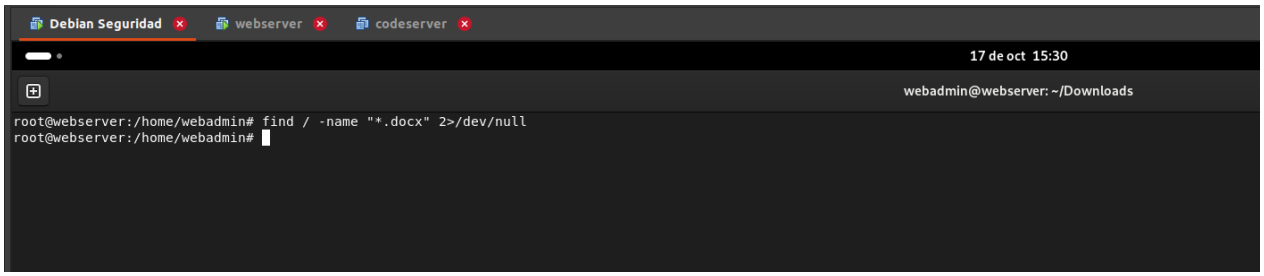


Figura 10: Busqueda de archivos con extension docx.



Figura 11: Busqueda del archivo contraseñas.txt en el directorio de root.



Figura 12: Busqueda del archivo passwords.xlsx.



Figura 13: Busqueda del archivo respaldo.zip.

Ademas de las busquedas por nombre exacto, se ampliaron los patrones para buscar cualquier archivo con extension xlsx y zip:

```
find / -name "*.xlsx" 2>/dev/null
find / -name "*.zip" 2>/dev/null
```

Para xlsx no se obtuvieron coincidencias. En el caso de zip aparecieron archivos de librerias y paquetes del sistema, pero esos nombres por si solos no comprueban que contengan contraseñas.

1.6.2. Busqueda de respaldos comprimidos

Para continuar con los archivos comprimidos, revisamos los que tienen la extension tar.gz. Para esto, el comando es el siguiente:

```
find / -name "*.tar.gz" 2>/dev/null
```



Figura 14: Busqueda de respaldos y otros archivos con extension tar.gz.

Donde en este caso, los archivos que nos interesan son los siguientes:

```
/home/webadmin/Downloads/home/developer2024/ProjectX_backup.tar.gz
/home/webadmin/Downloads/Project.old.tar.gz
/root/respaldo.tar.gz
```

No obstante, tambien se reviso si habia algun respaldo antiguo dentro de var, utilizando el siguiente comando:

```
find /var -name "*old.tar.gz" 2>/dev/null
```



Figura 15: Busqueda de respaldos antiguos dentro de var.

Esta busqueda no devolvio coincidencias dentro de var. Con esto, continuamos con los respaldos que ya se habian encontrado en Downloads y en el directorio de root.

1.6.3. Busqueda de nombres relacionados con contraseñas

Ahora bien, buscar solamente un nombre exacto puede dejar fuera otros archivos. Para ampliar la busqueda utilizamos las siguientes variaciones:

```
find / -type f -iname "*pass*.txt" 2>/dev/null
find / -type f -iname "*cred*.txt" 2>/dev/null
find / -type f -iname "*contra*.txt" 2>/dev/null
find / -type f -iname "*claves*" 2>/dev/null
```

Donde `-type f` permite buscar archivos regulares y `-iname` compara los nombres sin distinguir entre mayusculas y minusculas. Los asteriscos permiten que la palabra buscada se encuentre en cualquier parte del nombre.

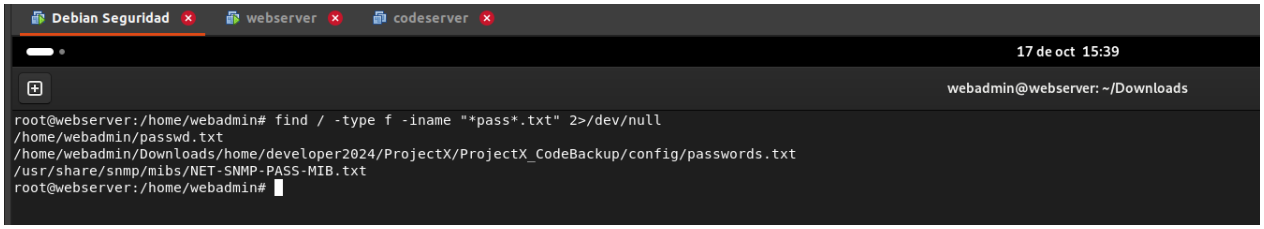


Figura 16: Busqueda de archivos de texto con pass en el nombre.

Para el patron pass se encontraron tres rutas, incluyendo passwd.txt, que ya se habia utilizado en la practica 5, y un archivo llamado passwords.txt dentro del respaldo de ProjectX. Este segundo archivo es el que vamos a revisar para comprobar si tiene contraseñas en claro.

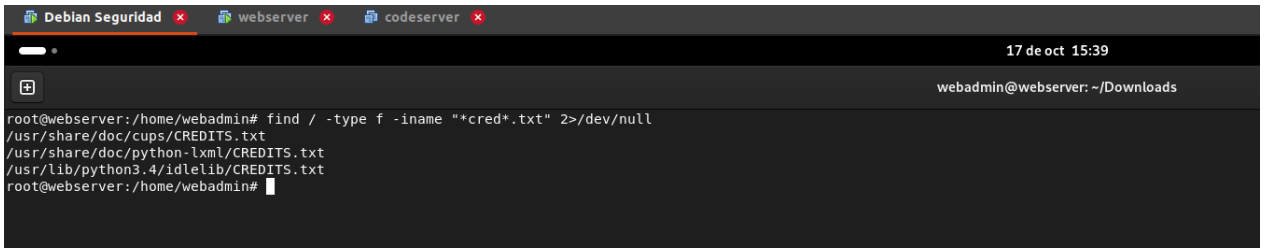


Figura 17: Busqueda de archivos de texto con cred en el nombre.



Figura 18: Busqueda de archivos con claves en el nombre.

Por otro lado, cred devolvio archivos CREDITS.txt y claves encontro archivos de un instrumento musical llamado Claves. Para contra no se obtuvieron resultados. Con esto podemos ver que encon-

trar una palabra en el nombre no significa que el archivo contenga credenciales; es necesario revisar su contenido.

1.6.4. Revision de los respaldos y del archivo passwords.txt

Para ver el contenido de los respaldos sin extraerlos de nuevo, utilizamos tar con las siguientes opciones:

```
tar -ztvf /root/respaldo.tar.gz
tar -ztvf /home/webadmin/Downloads/Project.old.tar.gz
```

Donde `-z` permite leer la compresion gzip, `-t` lista el contenido, `-v` agrega informacion de los archivos y `-f` indica el archivo que se va a revisar. En respaldo.tar.gz aparece flag2.txt, mientras que Project.old.tar.gz contiene la estructura del proyecto, incluyendo el directorio config y el archivo passwords.txt.

Despues de esto, para revisar el archivo que ya se encuentra dentro de Downloads, se utiliza el comando siguiente:

```
cat /home/webadmin/Downloads/home/developer2024/ProjectX/ProjectX_CodeBackup/config
    /passwords.txt
```

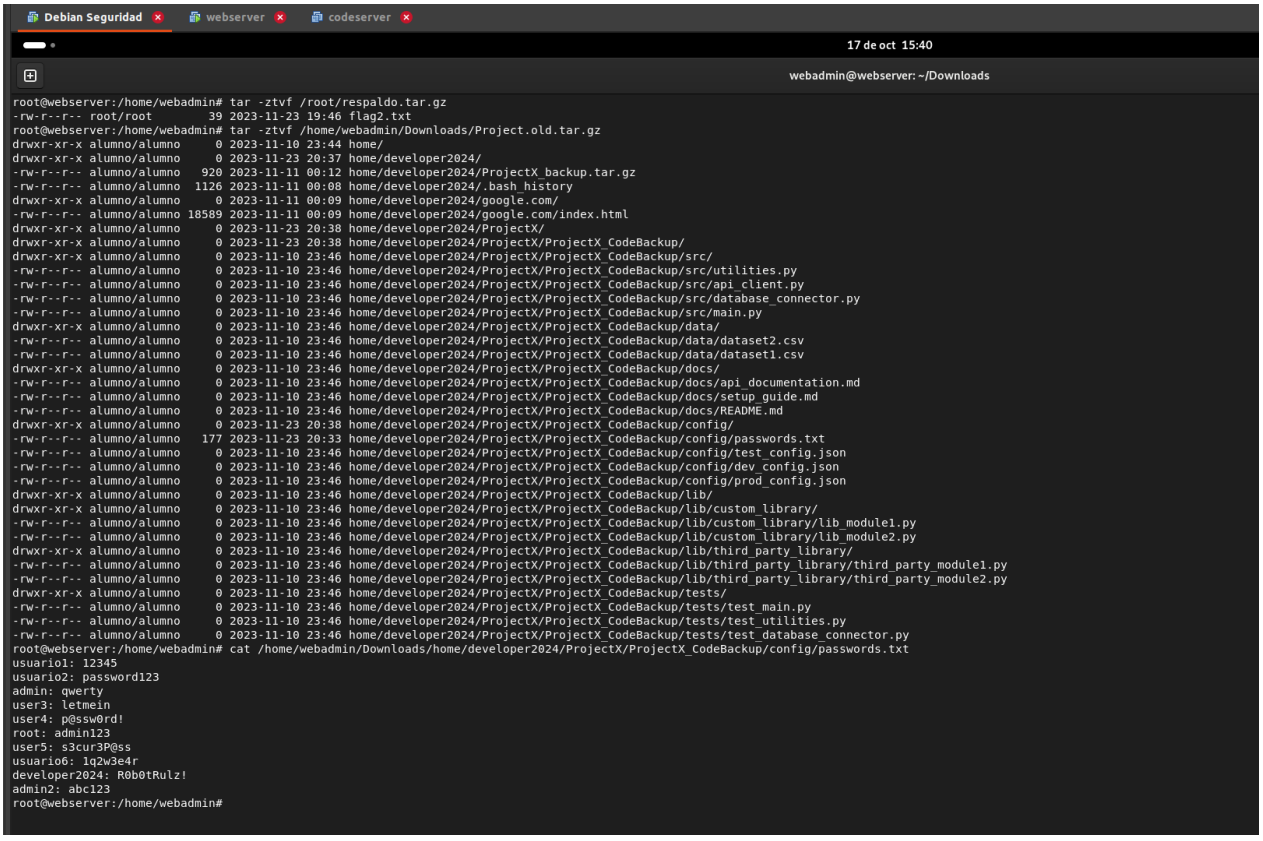


Figura 19: Revision de los respaldos y lectura del archivo passwords.txt.

Donde en este caso, el archivo contiene diez pares de usuario y contraseña escritos directamente en texto. El contenido es el siguiente:

```
usuario1: 12345
usuario2: password123
admin: qwerty
user3: letmein
user4: p@ssw0rd!
root: admin123
user5: s3cur3P@ss
usuario6: 1q2w3e4r
developer2024: R0b0tRulz!
admin2: abc123
```

Con esto se comprueba que el archivo si contiene contraseñas en claro, ya que se pueden leer sin realizar un proceso como el que se utilizo con John. No obstante, la entrada root: admin123 pertenece al archivo del respaldo y no demuestra que esa sea la contraseña actual del usuario root de webserver, donde la contraseña que utilizamos fue Maverick.

1.6.5. Busqueda de cadenas dentro de los archivos

Por ultimo, ademas de buscar por nombre, tambien se reviso el contenido de varios directorios. Para esto se utilizo grep con el siguiente comando:

```
grep -rnI --exclude="linpeas*" -iE "pass|contra|clave|user|admin" /root/ /home/
    webadmin/ /var/www/ /opt/ /etc/ 2>/dev/null
```

Donde `-r` hace la busqueda de forma recursiva, `-n` agrega el numero de linea, `-I` omite archivos binarios, `-i` no distingue entre mayusculas y minusculas y `-E` permite utilizar la expresion con varias palabras separadas por `|`. Ademas de que, `--exclude="linpeas*"` deja fuera los archivos cuyo nombre empieza con linpeas.

Esta busqueda devolvio coincidencias del archivo passwords.txt, junto con comentarios, configuraciones y otros archivos del sistema. Por lo que no todas las coincidencias corresponden a una contraseña; para esta practica el archivo que se comprobo fue el del respaldo de ProjectX.

1.7. Construccion y transferencia del escaner de red

Ahora bien, como webserver tiene la interfaz eth1 en otra red, lo que vamos a hacer es revisar que otros equipos se encuentran conectados a ese segmento. Para esto se preparo un archivo llamado escaner.sh en EvilBox, utilizando el comando siguiente:

```
nano escaner.sh
```

El codigo del escaner que se utilizo es el siguiente:

```
#!/bin/bash
# Escaner automatizado de Red (Ping + Netcat de puertos)
RED="10.0.0"

echo "[*] Iniciando barrido de ping en la red $RED.0/24..."
for ip in {1..254}; do
    # Envia 1 paquete de ping con un tiempo de espera de 1 segundo
    ping -c 1 -W 1 $RED.$ip > /dev/null 2>&1
    if [ $? -eq 0 ]; then
        echo "[+] Equipo activo encontrado: $RED.$ip"
        echo "    [*] Escaneando puertos (1-10000)..."
        # Escanea automaticamente el rango de puertos y filtra solo los abiertos
        nc -zv -w 1 $RED.$ip 1-10000 2>&1 | grep -i "open\|succeeded"
    fi
done
echo "[*] Escaneo de red finalizado."
```



Figura 20: Codigo del escaner de red en Bash.

Para entender lo que hace el programa, primero se define `RED="10.0.0"`, siendo esta la parte de la direccion que no cambia. Despues, el ciclo for recorre los valores del 1 al 254 y forma las direcciones que se van a revisar, dejando fuera la direccion de red y la de broadcast.

El comando `ping -c 1 -W 1` envia un solo paquete y espera hasta un segundo por la respuesta. La redireccion `> /dev/null 2>&1` oculta tanto la salida normal como los errores de ping. Despues, `$?` contiene el codigo de salida del ultimo comando y `-eq 0` comprueba si termino correctamente.

Si el equipo responde, se ejecuta nc para revisar sus puertos TCP del 1 al 10000. Donde `-z` comprueba los puertos sin intercambiar datos de aplicacion, `-v` muestra informacion del intento y `-w 1` establece un tiempo de espera de un segundo. La parte `2>&1` permite pasar tambien los mensajes de error a la tuberia y grep conserva las lineas que contienen open o succeeded.

No obstante, este escaner solo revisa puertos de los equipos que respondieron al ping. Ademas de que, el rango termina en 10000 y se utiliza TCP, por lo que los resultados corresponden a esas condiciones de la busqueda.

Despues de guardar el archivo, se copio al servidor por medio de scp. El comando completo es el siguiente:

```
scp -P 13337 escaner.sh webadmin@192.168.177.129:/home/webadmin/
```

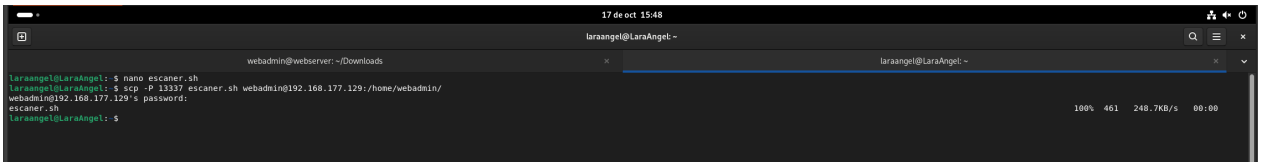


Figura 21: Transferencia de escaner.sh desde EvilBox a webserver.

Donde `-P` indica el puerto SSH del servidor, escaner.sh es el archivo local que se copia y `/home/webadmin/` es el directorio de destino. Para autorizar la copia se utilizo la contraseña de webadmin.

Una vez dentro de webserver, se revisaron los archivos con ls y se dieron permisos de ejecucion al escaner:

```
ls
chmod +x /home/webadmin/escaner.sh
```

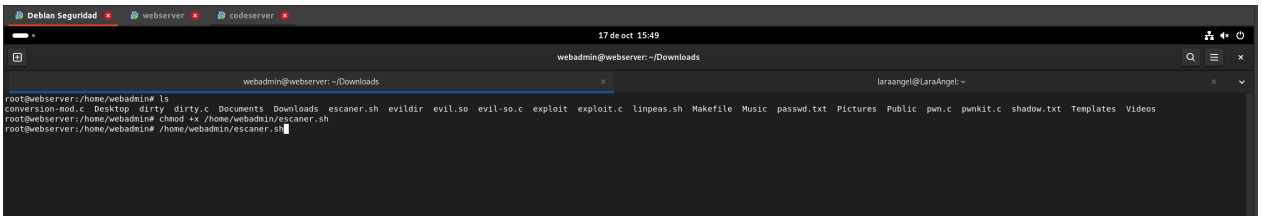


Figura 22: Verificacion del archivo y asignacion del permiso de ejecucion.

Lo que hace `chmod +x` es agregar el permiso para ejecutar el archivo. Despues de esto, desde el directorio de webadmin, se pone el siguiente comando:

```
./escaner.sh
```

1.8. Equipos encontrados y revision de los servicios

La salida del escaner nos arroja dos equipos activos en la red interna, siendo `10.0.0.78` y `10.0.0.201`. Donde el primero corresponde al mismo webserver por su interfaz eth1, mientras que el segundo es el otro equipo encontrado.

```
Equipo activo encontrado: 10.0.0.78
111/tcp open
80/tcp open
```

```
Equipo activo encontrado: 10.0.0.201
5985/tcp open
3389/tcp open
445/tcp open
139/tcp open
135/tcp open
80/tcp open
```

Para el equipo distinto a webserver se encontraron seis puertos TCP abiertos dentro del rango que reviso el escaner. Ahora bien, para identificar mejor los servicios de los puertos 5985 y 3389, se ejecutaron los siguientes comandos:

```
sudo nmap -sV -p 5985 10.0.0.201
sudo nmap -sV -p 3389 10.0.0.201
```

Donde `-sV` intenta identificar el servicio y su version, `-p` indica el puerto que se va a revisar y al final se pone la direccion del equipo. Para el puerto 5985, nmap devuelve lo siguiente:

```
PORT     STATE SERVICE VERSION
5985/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows
```

Por otro lado, para el puerto 3389 se obtiene el siguiente resultado:

```
PORT     STATE SERVICE       VERSION
3389/tcp open  ms-wbt-server Microsoft Terminal Service
Service Info: OS: Windows
```

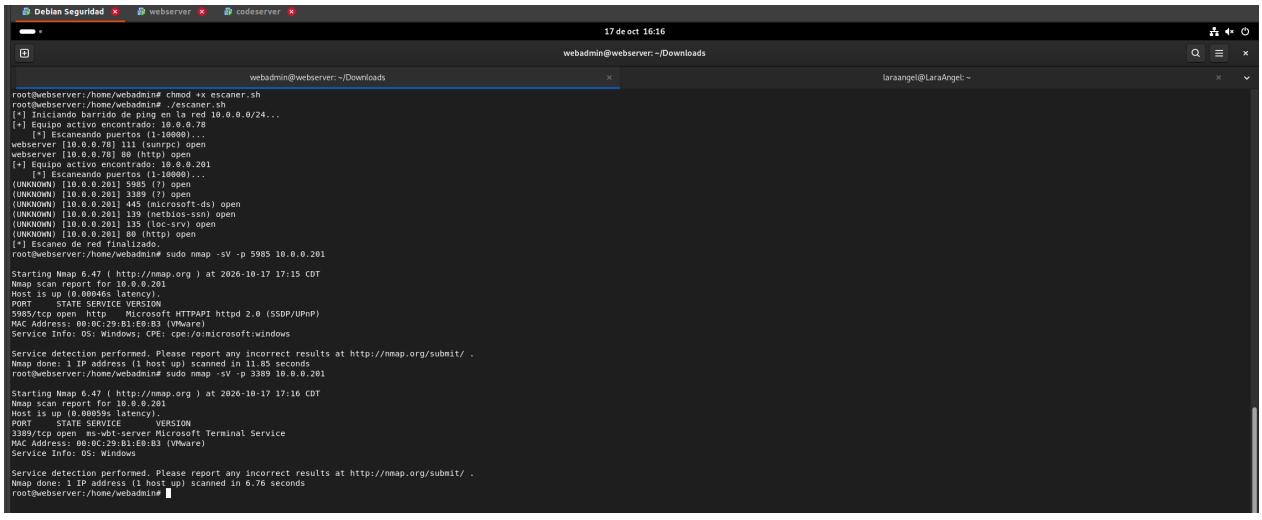


Figura 23: Resultados del escaner e identificacion de los servicios en 10.0.0.201.

Con esto podemos ver servicios de Windows. El puerto 3389 corresponde a escritorio remoto y el 5985 devuelve Microsoft HTTPAPI, coincidiendo con el puerto habitual de WinRM. Hasta este punto se identificaron servicios, sin iniciar sesion en el otro equipo.

2. Actividades

2.1. Actividad 1: Version del kernel

¿Cual es la version del kernel del equipo webserver?

Utilizamos el comando uname que se ejecuto durante el desarrollo. El comando es el siguiente:

```
uname -v
```

```
#1 SMP Debian 3.16.56-1+deb8u1 (2018-05-08)
```

Donde en este caso, la version de compilacion obtenida es `3.16.56-1+deb8u1`, con fecha del 8 de mayo del 2018. La bandera utilizada fue `-v`, por lo que este valor corresponde a la informacion de compilacion del kernel.



Figura 24: Comprobacion de la version del kernel y de la distribucion.

2.2. Actividad 2: Valor de PRETTY_NAME

¿Cual es el valor de la variable PRETTY_NAME?

Para esto, revisamos el resultado del comando que muestra la informacion de la distribucion:

```
cat /etc/*release | uniq
```

```
PRETTY_NAME="Debian GNU/Linux 8 (jessie)"
```

Por lo que, el valor de PRETTY_NAME es `Debian GNU/Linux 8 (jessie)`. Este campo contiene el nombre completo de la distribucion instalada en webserver.

2.3. Actividad 3: Comando del servicio SSH

¿Cual es el comando que ejecuta el servicio SSH en el equipo webserver?

Para encontrarlo, revisamos la columna COMMAND del resultado de ps, utilizando el siguiente comando:

```
ps aux awf
```

```
/usr/sbin/sshd -D
```

Donde `/usr/sbin/sshd` es el programa del servidor SSH y la opcion `-D` hace que se mantenga en primer plano. El proceso principal se ejecuta como root y tiene el PID 486.

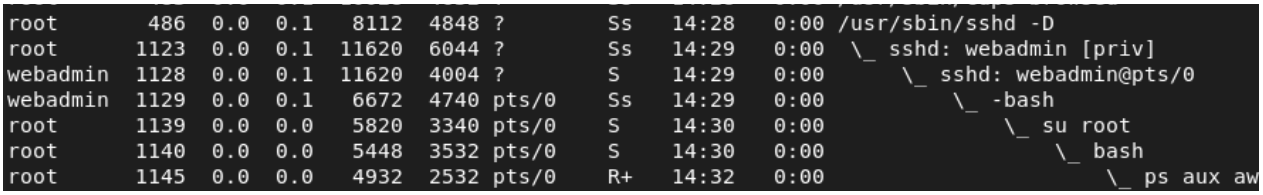


Figura 25: Proceso principal de SSH y procesos de la sesion de webadmin.

2.4. Actividad 4: Comando del servicio Apache

¿Cual es el comando que ejecuta el servicio Apache en el equipo webserver?

De igual forma, en el listado que nos dio ps se identifica el proceso de Apache. El comando que aparece es el siguiente:

```
/usr/sbin/apache2 -k start
```

Donde `/usr/sbin/apache2` es el programa del servidor web y `-k start` indica el inicio del servicio. El proceso principal tiene el PID 808 y se ejecuta como root, mientras que los procesos hijos se ejecutan con el usuario www-data.

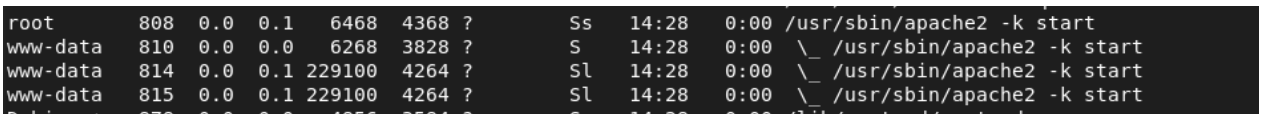


Figura 26: Proceso principal de Apache y procesos hijos de www-data.

2.5. Actividad 5: Interfaces de red configuradas

¿Cuantas interfaces de red estan configuradas en el equipo webserver?

Para esto, utilizamos el resultado del siguiente comando:

```
ifconfig -a
```

El equipo tiene **tres interfaces**, siendo `eth0`, `eth1` y `lo`. Donde las dos primeras son interfaces Ethernet y la tercera es la interfaz de loopback. Por lo que, si se cuentan solamente las interfaces Ethernet son dos, pero el total que devuelve ifconfig -a es tres.

```
root@webserver:/home/webadmin# ifconfig -a
eth0      Link encap:Ethernet  HWaddr 00:0c:29:d6:69:6d
          inet addr:192.168.177.129  Bcast:192.168.177.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fed6:696d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1896 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1210 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:155288 (151.6 KiB)  TX bytes:105018 (102.5 KiB)
          Interrupt:19 Base address:0x2000

eth1      Link encap:Ethernet  HWaddr 00:0c:29:d6:69:77
          inet addr:10.0.0.78  Bcast:10.0.0.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fed6:6977/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:682 errors:0 dropped:0 overruns:0 frame:0
          TX packets:89 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:79058 (77.2 KiB)  TX bytes:12726 (12.4 KiB)
          Interrupt:18 Base address:0x2080

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:32 errors:0 dropped:0 overruns:0 frame:0
          TX packets:32 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:3488 (3.4 KiB)  TX bytes:3488 (3.4 KiB)

root@webserver:/home/webadmin#
```

Figura 27: Interfaces eth0, eth1 y lo configuradas en webserver.

2.6. Actividad 6: Direccion de la interfaz eth1

¿Cual es la direccion IP configurada en la interfaz eth1?

Dentro de la informacion de ifconfig -a se revisa el apartado de eth1. Donde en este caso, los datos son los siguientes:

```
eth1
inet addr:10.0.0.78
Bcast:10.0.0.255
Mask:255.255.255.0
```

Por lo que la direccion IP de eth1 es **10.0.0.78**, con mascara `255.255.255.0`. Esto nos permite identificar que la red interna a revisar es `10.0.0.0/24`.

2.7. Actividad 7: Ruta del archivo con contraseñas en claro

¿Cual es la ruta absoluta del archivo que contiene contraseñas en claro?

Para encontrar el archivo, primero se amplio la busqueda de nombres con el comando siguiente:

```
find / -type f -iname "*pass*.txt" 2>/dev/null
```

Despues se reviso el contenido del archivo passwords.txt con cat. La ruta absoluta es la siguiente:

```
/home/webadmin/Downloads/home/developer2024/ProjectX/ProjectX_CodeBackup/
    config/passwords.txt
```

El archivo contiene diez pares de usuario y contraseña, entre ellos `usuario1: 12345`, `admin: qwerty` y `developer2024: R0b0tRulz!`. Con esto se comprobo que son contraseñas en claro y no hashes como los que se obtuvieron de shadow en la practica anterior.



Figura 28: Ruta y contenido del archivo passwords.txt.

2.8. Actividad 8: Otro equipo en la red interna

¿Cual es la direccion IP del equipo distinto a webserver que esta conectado a la misma red configurada en la interfaz eth1?

Se utilizo el escaner desde webserver sobre la red 10.0.0.0/24. La ejecucion se realizo con el siguiente comando:

```
./escaner.sh
```

```
Equipo activo encontrado: 10.0.0.78
Equipo activo encontrado: 10.0.0.201
```

Donde `10.0.0.78` es la direccion de eth1 del mismo webserver. Por lo tanto, la direccion del otro equipo encontrado es **10.0.0.201**, correspondiente al equipo que se buscaba en la red interna.

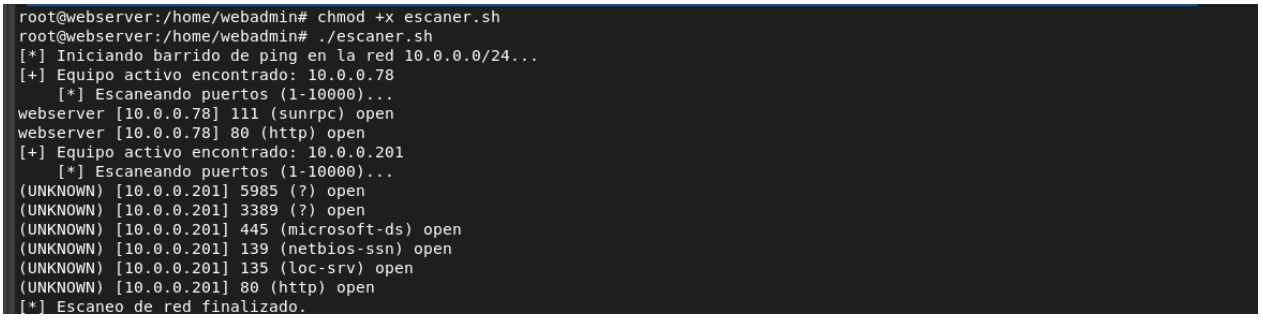


Figura 29: Equipo distinto a webserver y puertos encontrados en la red interna.

2.9. Actividad 9: Puertos a la escucha del otro equipo

¿Cuantos puertos a la escucha estan configurados en el equipo distinto a webserver que esta conectado a la misma red configurada en la interfaz eth1?

Para esto, tomamos los resultados de nc para 10.0.0.201. Donde en este caso se encontraron **seis puertos TCP abiertos**, siendo los siguientes:

Puerto TCP	Servicio o asociacion habitual
80	HTTP
135	RPC de Windows
139	NetBIOS
445	SMB
3389	Escritorio remoto, confirmado con nmap
5985	Puerto habitual de WinRM sobre HTTP

Este conteo corresponde al rango del 1 al 10000 que se reviso con el escaner. Por lo que la respuesta obtenida es seis dentro de ese rango; no se revisaron los puertos TCP superiores a 10000 ni puertos UDP.

2.10. Actividad 10: Puerto para establecer una sesion remota

¿Cual es el puerto que permite establecer una sesion remota al equipo distinto a webserver que esta conectado a la misma red configurada en la interfaz eth1?

Para la administracion remota por WinRM, el puerto identificado es **5985/TCP**. Para revisar el servicio que responde en ese puerto se utilizo el comando siguiente:

```
sudo nmap -sV -p 5985 10.0.0.201
```

```
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
```

Donde el puerto coincide con el que utiliza WinRM por HTTP. No obstante, tambien se encontro abierto el **3389/TCP**, que permite escritorio remoto y se identifico con el siguiente comando:

```
sudo nmap -sV -p 3389 10.0.0.201
```

```
3389/tcp open ms-wbt-server Microsoft Terminal Service
```

Por lo que, para una sesion de administracion por WinRM se considera el puerto 5985, mientras que para una sesion grafica de escritorio remoto se tiene el puerto 3389. En esta parte se identificaron los servicios, sin realizar todavia una conexion autenticada al otro equipo.

Referencias

Debian. (s.f.-a). *find(1): findutils, Debian jessie*. Consultado el 17 de octubre de 2026, desde https://manpages.debian.org/jessie/findutils/find.1.en.html

Debian. (s.f.-b). *nc.traditional(1): netcat-traditional*. Consultado el 17 de octubre de 2026, desde https://manpages.debian.org/bookworm/netcat-traditional/nc.traditional.1.en.html

Microsoft. (s.f.). *Installation and configuration for Windows Remote Management*. Consultado el 17 de octubre de 2026, desde https://learn.microsoft.com/en-us/windows/win32/winrm/installation-and-configuration-for-windows-remote-management

Nmap Project. (s.f.). *Port Specification and Scan Order*. Consultado el 17 de octubre de 2026, desde https://nmap.org/book/man-port-specification.html